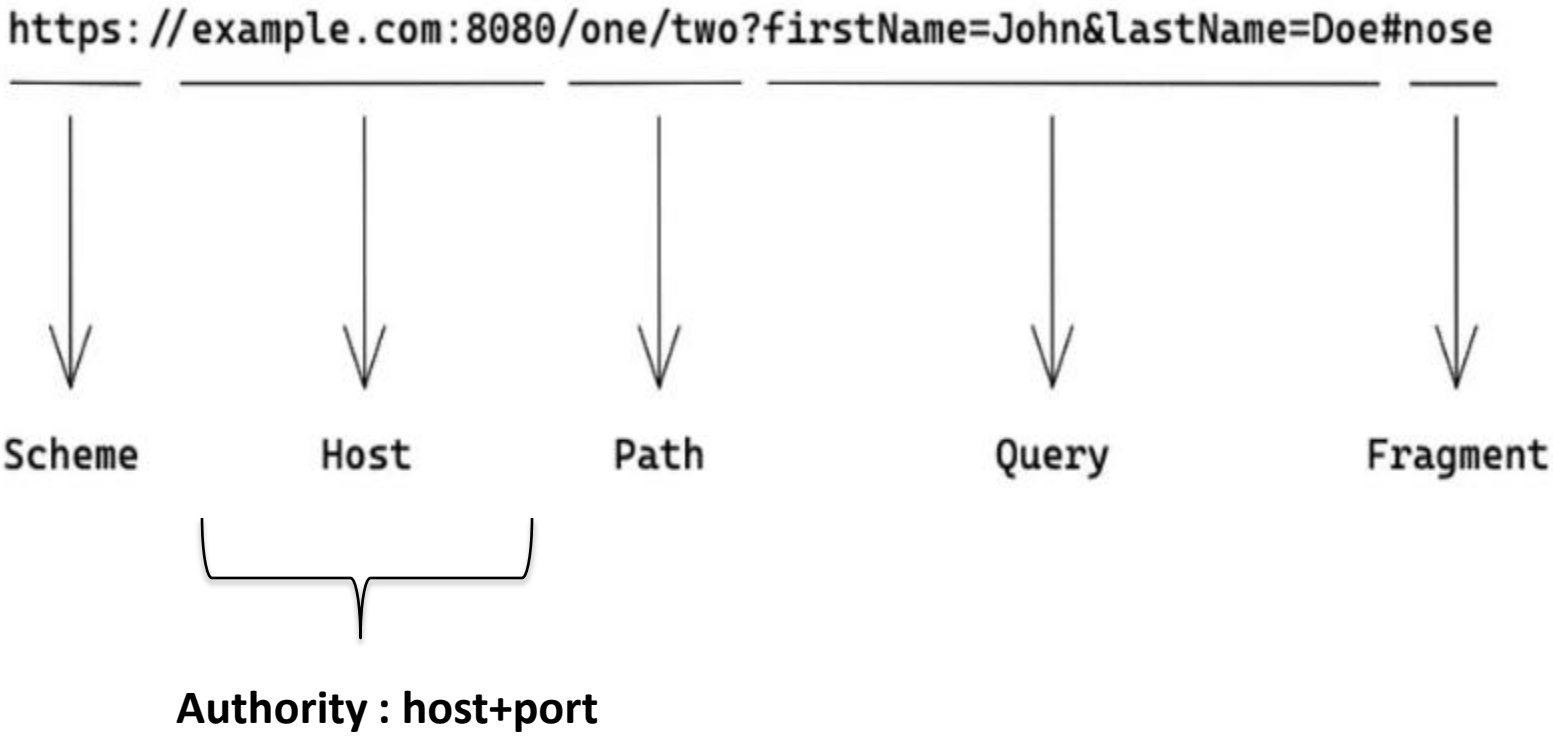
Etude de cas: Le phishing

- Le phishing une méthode d'ingénierie sociale utilisée pour tromper les victimes et leur faire révéler des informations sensibles.
- les attaques de phishing sont souvent utilisées comme première étape pour déployer des logiciels malveillants ie. des rançongiciels, en incitant la victime à cliquer sur un lien ou à télécharger une pièce jointe infectée.

Etude de cas: Le phishing

- **Structure Standard (RFC 3986)**



Etude de cas: Le phishing

- **Composants Critiques pour la Sécurité**
- **Schéma (Scheme) :**
- http/https : risque si HTTP
- javascript: Exécution de code côté client (danger)
- data: : URLs incorporant des données
- file: : Accès système local (danger en contexte web)

Etude de cas: Le phishing

Authority (Userinfo@Host:Port) :

- **Userinfo** : username:password@ (obsolète, risque fuite)
- **Host** : Domaine ou IP (IP directe = suspect)
- **Port** : Déviations des ports standards = suspicion

Chemin et Paramètres :

- **Path** : Structure révélant l'application
- **Query** : ?key=value&key2=value2 (données sensibles)
- **Fragment** : #section (côté client uniquement)

Etude de cas: Le phishing

A.Menaces et Techniques d'Attaque par URL

- **Obfuscation et Contournement**

<u>Encodage URL :</u>

Simple : %20 (espace), %2F (slash)

Double : %2520 → %20 → espace (contournement filtres)

UTF-8/Unicode : Caractères internationaux pour homoglyphes

<u>Ex: Syntaxe Trompeuse :</u>

https://google.com@exemple.com(Se connecte à exemple.com avec identifiant google.com)

https://google.com:80@exemple.com (Plus discret)

https://google.com%40exemple.com (Encodé)

Etude de cas: Le phishing

- **Attaques par Ingénierie Sociale**
- **Typosquatting :**

Omission : gogle.com, facebok.com

Ajout : faceebook.com, gooogle.com

Substitution : g00gle.com, paypai.com

Homoglyphes : paypal.com (cyrillique)

- **Sous-domaines Trompeurs :**

https://paypal.com.exe.com/ (Sous-domaine de ex.com)

https://exe.com/paypal.com/ (Chemin contenant paypal.com)

Les techniques utilisées pour l'analyse d'un malware:

L'analyse statique

L'analyse Dynamique

Hybride

L'analyse statique

L'analyse statique est une méthode d'étude des logiciels malveillants qui consiste à examiner le code sans l'exécuter(comme analyser les plans d'un bâtiment sans y entrer).

Quelques techniques et outils d'analyse statique

Technique 1 - L'Empreinte Numérique (Hashing)

- **Utilité :** Identifier rapidement un malware connu dans une base de données.

```
PS C:\Users\X1 Carbon> Get-FileHash -Path "C:\Users\X1 Carbon\Desktop\Strings\Eula.txt" -Algorithm SHA256

Algorithm       Hash                                                                   Path
---------       ----                                                                   ----
SHA256          8329BCBADC7F81539A4969CA13F0BE5B8EB7652B912324A1926FC9BFB6EC005A       C:\Users\X1 Carbon\Desktop\St
```

L'analyse statique

Technique 2 - La Recherche de Strings: Un string est une chaîne de caractère dans un programme, et un programme contient des Strings s'il affiche un message, s'il se connecte à internet (IPs, URL ou domaine) ou s'il copie, déplace ou crée un fichier dans un répertoire spécifique.

Ex.

```
C:\Users\Hostname\Desktop > strings hello.exe
KN12
kv@
$L!
www.google.com
GetLayout
GDI32.DLL
SetLayout
153.42.13.64
ML+
You can use this link safely
```

L'analyse statique

Technique 3 - L'Analyse des En-têtes PE (Windows)

- **Concept :** Analyser la structure du fichier exécutable Windows (Portable Executable).
- **Utilité :** Obtenir des informations sur les bibliothèques (DLL) importées, l'horodatage de compilation, les sections.
- **Outils :** PEview, PEstudio, CFF Explorer.
- **Exemple** PEstudio montrant les DLL importées (comme GD132.DLL).

L'analyse statique

Technique 4 - L'Analyse du Code (Désassemblage)

Transformer le code binaire (compréhensible seulement par la machine) en code assembleur (partiellement compréhensible par les humains).

- **Utilité :** Comprendre la logique interne et les fonctions complexes du malware.
- **Outils : IDA Pro** (le plus connu), **Ghidra** (gratuit, de la NSA), **Binary Ninja**.
- **Point Important :** C'est la technique la plus avancée de l'analyse statique.

Autre Techniques…

Avantages de l'Analyse Statique

Points Forts

- **Sécurité totale** : Pas de risque d'infection
- **Rapide** pour les signatures connues
- **Compréhension profonde** de l'architecture
- **Détection précoce** des familles de malwares

Limitations

- **Peut manquer** le comportement réel
- **Contournable** par le chiffrement/obfuscation
- **Plus technique** et complexe
- **Ne voit pas** les actions conditionnelles

Analyse Dynamique

- L'analyse dynamique est une méthode d'étude des logiciels malveillants qui consiste à exécuter le programme dans un environnement contrôlé et isolé pour observer son comportement en temps réel.

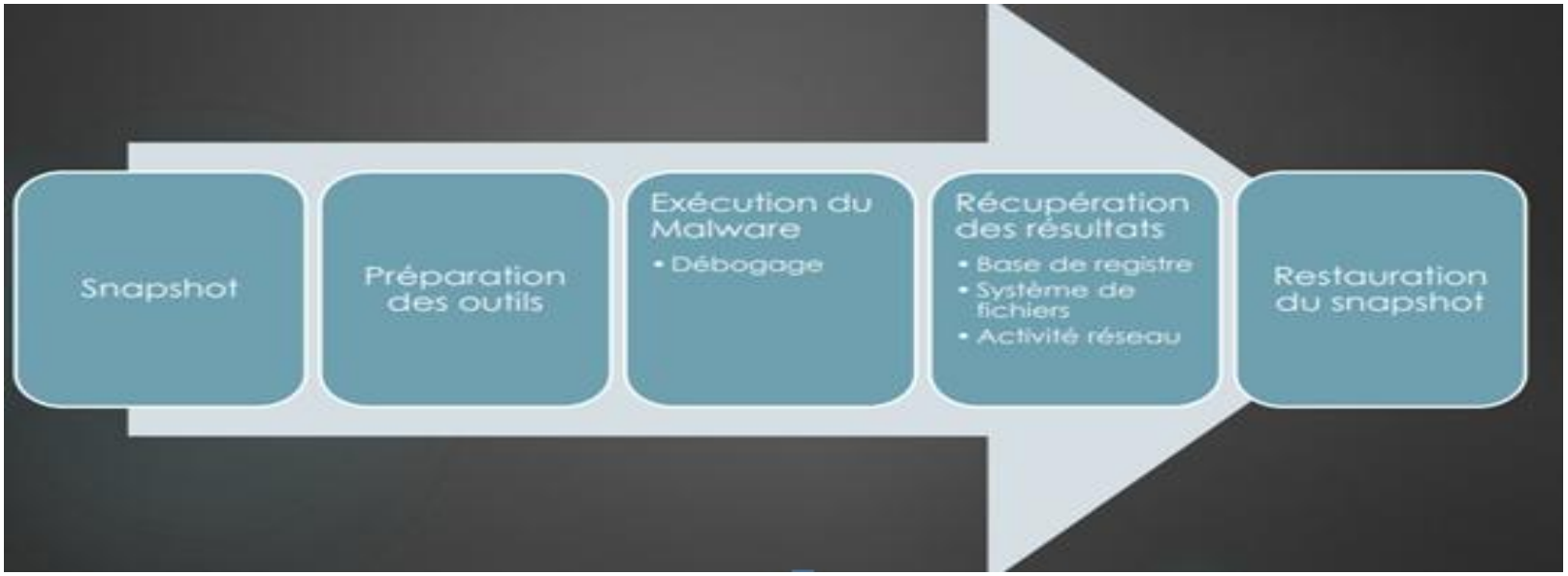
L'Environnement Contrôlé

- **Concept :** Il est crucial de ne *jamais* exécuter un malware sur une machine physique.
- **Solutions :**
  - **Machines Virtuelles (VM)** : VMware, VirtualBox.
  - **Sandbox dédiées** : Cuckoo Sandbox, Any.run, Hybrid Analysis.
- **Bonnes Pratiques :** Désactiver les partages de fichiers, mettre le réseau en mode "Host-Only" ou "NAT".

Pourquoi utiliser l'analyse dynamique ?

- Comprendre ce que le malware fait réellement (et pas seulement ce qu'il *pourrait* faire)
- Voir quelles modifications il apporte au système
- Identifier ses communications réseau
- Analyser son comportement sans mettre en danger de vrais systèmes

Les Étapes de l'Analyse Dynamique



Les Étapes de l'Analyse Dynamique

1. **Snapshot :** Avant d'exécuter le malware, on prend une"**Snapshot** " du système propre.
2. **Préparation des outils:** installe tous les logiciels qui vont nous aider à espionner le malware :
   - Analyseurs de réseau (Wireshark)
   - Moniteurs de registre (Regshot)
   - Analyseurs de processus (Process Monitor)
3. **Exécution du Malware :**On lance le programme malveillant dans notre environnement sécurisé.

Débogage:on utilise un débogueur pour examiner le code du malware pendant qu'il s'exécute, instruction par instruction.

Les Étapes de l'Analyse Dynamique

4. Récupération des résultats

Base de registre

Le malware a-t-il modifié les paramètres système ?

Créé des clés pour démarrer automatiquement ?

Système de fichiers

Quels fichiers a-t-il créés, modifiés ou supprimés ?

A-t-il chiffré des documents ?

Activité réseau

À quels serveurs s'est-il connecté ?

A-t-il téléchargé d'autres malwares ?

Envoyé des données volées ?

Les Étapes de l'Analyse Dynamique

5. Restauration du snapshot

restaure le système à son état propre initial Ainsi, l'environnement est prêt pour analyser le prochain malware.

L'analyse dynamique permet de **voir le malware en action** plutôt que de simplement lire son code, ce qui donne une compréhension beaucoup plus concrète de sa dangerosité.

Une Approche Combinée-hybride

- Les deux méthodes sont **complémentaires**.
- **Processus type :**
  - **Analyse Statique Rapide** pour une première identification.
  - Si le malware est inconnu ou complexe, passer à l'**Analyse Dynamique**.
  - Revenir à l'**Analyse Statique Avancée** (désassemblage) basée sur les comportements observés.